

Checklist operativa — Onboarding nuovi fornitori (Responsabili del trattamento)

MetaCare SRL · MeMindSport · Ai sensi degli artt. 28, 30 e 35 GDPR — versione 1.0 — 5 giugno 2026

Da compilare **PRIMA** di attivare qualsiasi nuovo fornitore esterno che tratti dati personali per conto del Titolare. Compilata da: _____ Data: __/__/____ Approvata dal DPO (Dott. Rolando Alberto Tavano, info@tavano.it): SI · NO

0. Dati identificativi del fornitore

Ragione sociale	
Sede legale / Paese	
Servizio fornito	
Categoria dati trattati	☐ Comuni ☐ Sanitari (Art. 9) ☐ Pagamento ☐ Altro: _____
Trasferimento extra-UE	☐ No ☐ Sì (Paese: _____)
Referente fornitore (email)	

1. Due diligence preliminare

- ☐ Verificata l'esistenza di garanzie sufficienti ex Art. 28(1) GDPR (certificazioni ISO 27001, SOC 2, codici di condotta).
- ☐ Richiesta e archiviata la privacy policy del fornitore.
- ☐ Verificata l'ubicazione dei server (preferibilmente UE/SEE).
- ☐ Se extra-UE: verificate Clausole Contrattuali Standard (SCC 2021/914) e Transfer Impact Assessment (TIA).
- ☐ Per fornitori USA: verificata adesione al Data Privacy Framework (DPF).

2. Sottoscrizione DPA (Data Processing Agreement)

- ☐ Richiesto al fornitore il template DPA (o proposto il template MetaCare).
- ☐ DPA contiene tutti gli elementi ex Art. 28(3) GDPR: oggetto, durata, natura, finalità, tipi di dati, categorie interessati, obblighi del Responsabile.
- ☐ Sub-responsabili: autorizzazione generale o specifica documentata.
- ☐ Diritto di audit del Titolare previsto.
- ☐ Notifica data breach entro 24-72h prevista.
- ☐ Restituzione/cancellazione dati a fine rapporto prevista.
- ☐ DPA firmato da entrambe le parti e archiviato (cartella: /Legale/DPA/).

3. Valutazione rischio & DPIA

- ☐ Valutato se il trattamento richiede DPIA ex Art. 35 (alto rischio, dati sanitari su larga scala, profilazione, monitoraggio sistematico).
- ☐ Se SI: DPIA completata e archiviata PRIMA dell'attivazione.

- ☐ Se trattamento di dati sanitari (Art. 9): verificata base giuridica del trasferimento (consenso esplicito già raccolto o nuovo consenso da raccogliere).
- ☐ Consultato il DPO (parere documentato via email).

4. Aggiornamento Privacy Policy

- ☐ Aggiunto il fornitore alla sezione 7 "Destinatari e responsabili esterni" di src/routes/privacy.tsx.
- ☐ Indicato: nome fornitore + servizio + ubicazione server + link alla privacy policy.
- ☐ Aggiornato numero di versione e data in cima al documento.
- ☐ Se cookie/analytics: aggiornata anche src/routes/cookie.tsx.
- ☐ Se modifica sostanziale: notifica via email agli utenti registrati.

5. Aggiornamento Registro del Trattamento (Art. 30)

- ☐ Aggiunta nuova riga al Registro del Trattamento (foglio "Responsabili esterni").
- ☐ Campi compilati: fornitore, dati trattati, finalità, base giuridica, durata, misure di sicurezza, trasferimenti extra-UE, riferimento DPA.
- ☐ Aggiornata data di ultima revisione del Registro.

6. Aggiornamento CMP / Cookie Banner (se applicabile)

- ☐ Se il fornitore installa cookie/script: aggiunta nuova categoria o voce nel ConsentContext.
- ☐ Script caricato condizionalmente tramite (blocco prima del consenso).
- ☐ Testato che il banner mostri il fornitore e che lo script NON parta prima dell'accettazione.

7. Misure tecniche e organizzative

- ☐ Credenziali fornitore archiviate in password manager aziendale (mai in chiaro nel codice).
- ☐ Accesso limitato al principio di minimo privilegio (least privilege).
- ☐ MFA attivata sull'account amministrativo del fornitore.
- ☐ Configurati alert su accessi anomali / data export.

8. Attivazione e monitoraggio

- ☐ GO/NO-GO firmato dal DPO.
- ☐ Data di attivazione registrata: __/__/____
- ☐ Inserita revisione annuale in calendario (data prossimo audit: __/__/____).
- ☐ Documentazione archiviata in /Legale/Fornitori// (DPA + DPIA + screenshot config + email DPO).

Firma e archiviazione

Compilato da	Verificato dal DPO	Approvato dal Titolare
Nome e data	Dott. R.A. Tavano — info@tavano.it	MetaCare SRL

MetaCare SRL — Via Pola 7, 33033 Codroipo (UD) — C.F./P.IVA 03102350307 — Autorizzazione Sanitaria n. 4710 del 13/01/2026 — info@memindsport.it